

Software Vulnerability Mitigations

Objectives

- Cross-Site Scripting
 - Output Encoding
 - HTML Sanitization
 - Input sanitization
 - WAF
 - Safe Sinks
 - No "innerHTML"
 - Use "textContent" or "value" instead
- Overflow Vulnerabilities
 - SAST/DAST
 - Safe Coding Practices
 - Heed Warnings
 - Stack Canaries
 - Random values placed on the stack at runtime
 - Verified when returning to caller functions
 - If canary is overwritten with BoF, then an error is generated
 - Data Execution Prevention(DEP) - Windows
 - No Execute(NX) - Linux
 - Makes the stack Non-Executable
 - Address Space Layout Randomization(ASLR)
 - Varies the memory base address of the stack and other memory areas
- AI Data Poisoning
 - Bad data fed to Data Sets intended to produce incorrect outcomes
 - Targets AI/ML
 - Availability
 - Integrity
 - Mitigations
 - Standard security methods
 - Outlier Detection / Data Sanitization / Anomaly Detection
 - Human in the Loop
- Broken Access Control
 - Default Deny except from Public Resources
 - Minimize CORS usage
 - Disable Directory Listing
 - Move sensitive files out of Web Root
 - Log/Alert access control failures
 - Enable rate-limiting
- Cryptographic Failures
 - Classify all data
 - Prevents accidental exposure of sensitive data

- Ensure encryption of data
 - At Rest
 - In Motion
 - In Use(if possible)
 - Use Strongest encryption possible
 - Don't use encryption algs that are known to be weak
 - Use CSPRNG (Cryptographically Security Pseudo Random Number Generator) for IVs
- Injection Flaws
 - Sanitize User Input
 - Filters
 - Prepared Statements
 - Statements prepared beforehand
 - Parameterized Queries
 - Passes values to a query that then acts like a Prepared Statement
- Cross-Site Request Forgery
 - CRSF Tokens
- Directory Traversal
 - Input Validation/Sanitization
 - Append Root Directory to all API calls
- Insecure Design
- Security Misconfiguration
- End-of-Life or Outdated Components
- Identification and Authentication Failures
- Server-Side Request Forgery
 - Firewalls/ACLs
- Remote Code Execution
 - Sanitize user input
 - Secure application memory management
 - Inspect network traffic
- Privilege Escalation
- Remote/Local File Inclusions
 - Sanitize user input
 - WAF